Universidade Presbiteriana Mackenzie

GOVERNANÇA E COMPLIANCE EM TI

Prof. Cleórbete Santos

Universidade Presbiteriana Mackenzie

Pilares de um Programa de Compliance

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Pilares de um Programa de Compliance (Art. 42 do Decreto 8.420/2015):

- Suporte da Alta Administração (inciso I e IX);
- Gestão de Riscos (inciso V);
- Código de conduta, políticas e procedimentos (inciso II, III e VIII);
- Controles internos (incisos VI e VII);
- Treinamento e comunicação (inciso IV);
- Canais de denúncia (inciso X);
- Investigações internas (incisos XI e XII);
- Due Diligence (incisos XIII e XIV);
- Monitoramento e auditoria (inciso XV);

Pilares de um programa de Compliance

Suporte da Alta Administração (inciso I e IX):

- Convencer a Alta Administração;
- Definir o objetivo do programa de compliance;
- Conseguir o suporte e recursos para o programa;
- Engajar os envolvidos;

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Gestão de Riscos (inciso V):

- Levantar normas aplicáveis;
- Conscientizar sobre o projeto;
- Identificar riscos;
- Criar matriz de risco;
- Realizar entrevistas com os envolvidos;
- Identificar controles existentes;
- Identificar riscos residuais;
- Criar relatório;

Pilares de um programa de Compliance

Código de conduta, políticas e procedimentos (inciso II, III e VIII):

- Criar código de conduta;
- Criar políticas internas;
- Criar procedimentos internos;

Pilares de um programa de Compliance

Controles internos (incisos VI e VII):

- Escolher tipos de controles;
- Escolher formas de execução dos controles;

Pilares de um programa de Compliance

Capacitação (inciso IV):

1) Garantir a adesão dos líderes;
2) Criar plano de capacitação com base na organização;
3) Alocar recursos;
4) Escolher capacitações com base nos riscos prioritários;
5) Escolher temas e públicos;
6) Planejar e estabelecer metas;
    1) Formato EaD x presencial;
    2) Adesão obrigatória x voluntária;
    3) Capacitações genéricas x específicas;
7) Personalizar capacitações conforme os públicos;
8) Engajar os líderes;
9) Explanar sobre as vantagens das capacitações;
10) Monitorar as ações de capacitação;
11) Continuamente melhorar as ações de capacitação;
    1) Realizar benchmarking;

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Comunicação (inciso IV):

- Criar plano de comunicação;
- Escolher formas de comunicação;
- Analisar vantagens e desvantagens das formas de comunicação;
- Definir local de acesso conforme a forma de comunicação;
- Usar linguagem conforme o público;
- Criar canal de dúvidas;
- Monitorar e avaliar;

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Canais de denúncia (inciso X):

- Definir meios de denúncia;
- Definir o nome do canal de denúncia;
- Garantir requisitos de funcionamento;
- Definir forma de implantação;
- Definir forma de gerenciamento;
- Definir público-alvo;
- Definir infraestrutura do canal;
- Criar políticas e procedimentos do canal de denúncia;

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Investigações internas (incisos XI e XII):

- Selecionar equipe para investigações;
- Criar plano de investigação;
- Identificar, obter a analisar evidências necessárias;
- Realizar entrevistas;
- Criar relatório;

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Due Diligence (incisos XIII e XIV):

- Identificar terceiros que se relacionam com a organização;
- Identificar terceiros que requerem monitoração;
- Criar política e procedimentos de due diligence;
- Definir periodicidade de repetição do processo de due diligence;
- Identificar, obter a analisar informações necessárias;
- Realizar entrevistas;
- Criar relatório;

Pilares de um programa de Compliance

Monitoramento e auditoria (inciso XV):

Monitoramento:

- É procedimento interno com foco preventivo;
- Conduzido pela área de compliance;
- Objetiva a melhoria contínua;
- É executado continuamente;

Auditoria:

- Procedimento externo com foco reativo;
- Conduzida por parte externa (mesmo que pertença à organização);
- Objetiva identificar falhas e oportunidades;
- É executada de forma randômica, porém periódica;

Universidade Presbiteriana Mackenzie

Governança Corporativa

Governança Corporativa

A Governança Corporativa é o sistema pelo qual as empresas são dirigidas, monitoradas e incentivadas, envolvendo o relacionamento entre sócios, conselho de administração, diretoria e órgãos de fiscalização.

Seu objetivo principal é garantir que a gestão da empresa esteja alinhada aos interesses dos proprietários e demais partes interessadas (stakeholders), mitigando o chamado "conflito de agência" — que ocorre quando os executivos tomam decisões em benefício próprio e não da organização.

Os 4 Pilares da Governança Corporativa

1) **Transparência (Transparency)**: Ir além da obrigação legal de exibir números; é o desejo de informar sobre fatores que guiam a ação gerencial e que conduzem à preservação de valor.
2) **Equidade (Fairness)**: Tratamento justo e igualitário de todos os sócios e partes interessadas, respeitando seus direitos e deveres.
3) **Prestação de Contas (Accountability)**: Os agentes de governança devem prestar contas de sua atuação de modo claro, assumindo integralmente as consequências de seus atos e omissões.
4) **Responsabilidade Corporativa (Responsibility)**: Zelar pela viabilidade econômico-financeira da organização, reduzindo externalidades negativas e cuidando da longevidade do negócio (aspectos ambientais, sociais e de governança - ESG).

Universidade Presbiteriana Mackenzie

Governança de TI

Governança de TI

A Governança de TI é uma extensão da Governança Corporativa que foca especificamente em garantir que os investimentos em tecnologia gerem valor ao negócio e que os riscos de TI sejam mitigados.

Enquanto a Gestão de TI foca em "entregar serviços", a Governança de TI foca em "fazer as coisas certas para o negócio".

Universidade Presbiteriana Mackenzie

Pilares da Governança de TI

- **Alinhamento Estratégico**: A TI está apoiando os objetivos da empresa?
- **Entrega de Valor**: Os projetos de TI trazem o retorno esperado (ROI)?
- **Gestão de Riscos**: Os dados estão seguros e os sistemas são resilientes?
- **Gestão de Recursos**: A infraestrutura e as pessoas estão sendo usadas de forma otimizada?
- **Mensuração de Desempenho**: Há métricas claras (KPIs) para saber se a TI está indo bem?

Balanced Scorecard

Balanced Scorecard

Balanced Scorecard (BSC), ou Indicadores de Desempenho Balanceados, é uma metodologia de gestão estratégica que serve para medir o desempenho de uma empresa além dos números financeiros.

Significado de "Balanced" (Balanceado)

Balanced Scorecard (BSC) busca o equilíbrio entre:

- Curto prazo e Longo prazo: O lucro de hoje vs. o investimento no futuro;

- Indicadores Externos e Internos: O cliente vs. a eficiência da fábrica;

- Passado e Futuro: O que a empresa faturou vs. o quanto está aprendendo para inovar.

Balanced Scorecard

Em termos práticos, BSC é um sistema que transforma a missão e a estratégia de uma organização em um conjunto de objetivos e medidas tangíveis, organizados em quatro perspectivas:

- Financeira: Indicadores de lucro e valor para o acionista;
- Clientes: Indicadores de satisfação e participação de mercado;
- Processos Internos: Indicadores de qualidade e eficiência da operação;
- Aprendizado e Crescimento: Indicadores de treinamento, cultura e tecnologia.

Perspectiva Financeira

Para sermos bem-sucedidos, como devemos aparecer para nossos acionistas?

O foco: Lucro, faturamento, retorno sobre investimento. É o resultado final.

Perspectiva do Cliente

Como os clientes nos veem?

O foco: Satisfação, fidelidade, se a marca é amada. Se o cliente está bravo, o lucro de hoje não vai se repetir amanhã.

Perspectiva de Processos Internos

Em quais processos devemos ser excelentes?

O foco: A operação. A entrega é rápida? O produto tem defeito? A "cozinha" da empresa precisa estar brilhando para o cliente ficar feliz.

Aprendizado e Crescimento

Como podemos continuar a melhorar e criar valor?

O foco: Pessoas e tecnologia. Se os funcionários estão desmotivados ou usando ferramentas antigas, a "cozinha" vai travar, o cliente vai reclamar e o lucro vai diminuir.

Resumo

Se a empresa capacitar os funcionários (Aprendizado), eles farão um serviço sem erros (Processos), o que deixará o cliente encantado (Clientes), e isso fará o lucro subir (Financeiro).

Passo a passo para aplicar BSC

Passo a passo para aplciar BSC

Passo 1: Defina o Destino (A Visão)

Onde sua empresa quer estar daqui a 1 ou 2 anos? Ex: "Ser a cafeteria mais recomendada do bairro";

Passo 2: Escolha os Objetivos

Aprendizado e Crescimento (Pessoas): O que sua equipe precisa aprender? Ex: Treinar a equipe em atendimento consultivo;

Processos Internos (Operação): O que precisa funcionar bem? Ex: Reduzir o tempo de preparo dos pedidos.

Clientes (Mercado): Como o cliente deve enxergar a empresa? Ex: Aumentar o índice de satisfação (NPS).

Financeira (Resultado): Qual o resultado final no bolso? Ex: Aumentar o faturamento mensal.

Universidade Presbiteriana Mackenzie

Passo a passo para aplciar BSC

Passo 3: Crie o Painel de Controle (KPIs e Metas)

Para cada objetivo do Passo 2, defina como medir e onde quer chegar.

Objetivo	KPI (Indicador)	Meta
Treinar equipe	% de funcionários certificados	100% da equipe
Reduzir tempo de preparo	Tempo médio (minutos)	Máximo 5 minutos
Satisfação do cliente	Nota de avaliação (0 a 10)	Média acima de 9
Aumentar faturamento	Valor total em Reais	R$ 50.000 / mês

Passo a passo para aplicar BSC

Passo 4: Desenhe o Mapa Estratégico

Conecte os pontos com setas de baixo para cima. Isso ajuda a equipe a entender o "porquê" de cada tarefa.

Equipe treinada -> faz o café rápido -> deixa o cliente feliz -> gera mais faturamento.

Passo 5: Tire do Papel (Iniciativas)

Defina uma ação prática para cada objetivo.

Ex: "Contratar uma consultoria de baristas" ou "Comprar uma máquina de café mais moderna".

Objetivo Estratégico no BSC

Objetivo Estratégico no BSC

A necessidade de definir um objetivo estratégico dentro do BSC nasce no exato momento em que a empresa percebe que ter apenas uma "Missão" (um sonho no quadro da parede) não faz as pessoas trabalharem melhor na segunda-feira de manhã.

Essa necessidade surge em três momentos cruciais:

1. Quando o "Sonho" precisa virar "Plano";
2. Quando a empresa percebe que "O que não é medido, não é gerenciado";
3. Para alinhar a equipe.

1. Quando o "Sonho" precisa virar "Plano"

Muitas empresas dizem: "Queremos ser a melhor cafeteria da cidade", porém isso é vago. A necessidade do objetivo estratégico nasce quando é necessário responder: "O que exatamente significa ser a melhor?".

É ter o café mais caro?

É atender mais rápido?

É ter o ambiente mais aconchegante?

O objetivo estratégico (ex: "Encantar o cliente") é a tradução desse sonho em algo que a equipe consiga visualizar.

2. Quando a empresa percebe que "O que não é medido, não é gerenciado"

Essa é uma frase clássica da administração.

A necessidade de definir o objetivo nasce quando o dono da empresa percebe que está perdendo dinheiro ou clientes, mas não sabe o porquê.

Se ele não definir o objetivo de "Aumentar a fidelidade", nunca vai criar o indicador para medir isso.

Sem o objetivo, o dono da empresa “está pilotando no escuro”.

3. Para alinhar a equipe

Quando o objetivo estratégico está definido:

- O Atendente sabe que deve ser simpático (Perspectiva do Cliente).

- O Barista sabe que o café não pode atrasar (Processos).

- O Gerente sabe que precisa investir em treinamento (Aprendizado).

Exemplo de definição de objetivo estratégico no BSC

O objetivo não pode ser vago ("ser feliz"). Ele precisa de um nome, uma métrica (indicador), uma meta e uma ação.

Componente	Descrição	Exemplo prático
Objetivo	O que queremos alcançar?	Aumentar a fidelidade dos clientes.
Indicador (KPI)	Como vamos medir isso?	Taxa de retorno (quantas vezes por mês o cliente vem à loja).
Meta	Qual o número de sucesso?	70% dos clientes devem retornar à loja ao menos 02 vezes por mês.
Plano de ação	O que faremos para chegar lá?	Criar um “cartão de fidelidade” (a cada 5 compras ganhe um desconto/produto).

Conexão com as outras perspectivas do BSC

A ideia é o cliente voltar (**Perspectiva do Cliente**).

O produto precisa ser bom e com qualidade (**Perspectiva de Processos**).

O vendedor precisa saber vender bem (**Perspectiva de Aprendizado**).

Se o cliente volta sempre, o faturamento aumenta (**Perspectiva Financeira**).

Exemplo de definição de objetivo estratégico no BSC

O objetivo não pode ser vago ("ser feliz"). Ele precisa de um nome, uma métrica (indicador), uma meta e uma ação.

Componente	Descrição	Exemplo prático
Objetivo	O que queremos alcançar?	Capacitar os funcionários na arte de cafés especiais.
Indicador (KPI)	Como vamos medir isso?	Percentual da equipe com certificação de Barista Nível 1.
Meta	Qual o número de sucesso?	100% da equipe técnica certificada até o final do semestre.
Plano de ação	O que faremos para chegar lá?	Contratar um mestre barista para um workshop intensivo de 3 dias.

Conexão com as outras perspectivas do BSC

Conexão com Processos Internos: Com baristas treinados, o preparo do café torna-se mais padronizado e rápido. O desperdício de grãos diminui porque eles sabem operar as máquinas com perfeição (Excelência Operacional).

Conexão com Clientes: O cliente percebe a diferença no sabor e na apresentação (o famoso desenho na espuma). Além disso, um funcionário que entende do que vende fala com propriedade, tira dúvidas e passa confiança (Encantamento do Cliente).

Conexão Financeira: Clientes encantados aceitam pagar um "ticket médio" maior por um café de alta qualidade e voltam mais vezes. Além disso, a redução de desperdício nos processos internos protege a margem de lucro (Aumento de Lucro).

COBIT

Universidade Presbiteriana Mackenzie

Definição

COBIT é um framework (um conjunto de boas práticas) criado pela ISACA para ajudar as empresas a alinhar a tecnologia com os objetivos de negócio.

Em termos simples o COBIT garante que a TI não esteja apenas mantendo a infraestrutura tecnológica, mas criando valor para a empresa crescer.

COBIT 2019

Control Objectives for Information and Related Technologies

5 Princípios Fundamentais (COBIT 5)

1. Atender às Necessidades dos Stakeholders: O foco é quem manda (acionistas, clientes). A TI deve entregar o que eles precisam;
2. Cobrir a Organização de Ponta a Ponta: A governança de TI não fica só no "departamento de informática"; ela permeia toda a empresa;
3. Aplicar um Framework Único e Integrado: O COBIT serve como um "guarda-chuva" que se conecta a outros padrões (como ITIL para serviços ou ISO para segurança);
4. Habilitar uma Abordagem Holística: Considera processos, pessoas, cultura e infraestrutura de forma conjunta;
5. Distinguir a Governança da Gestão:

5.1 Governança: Avalia, direciona e monitora (Estratégia);
5.2 Gestão: Planeja, constrói, executa e monitora (Operação).

Necessidades x COBIT

- A Diretoria quer: redução de custos, segurança e lucro;

- A TI quer: servidores novos, softwares modernos e estabilidade.

O COBIT traduz essas necessidades em objetivos de governança e gestão, organizados em 05 domínios, garantindo que os riscos sejam gerenciados e que o investimento em tecnologia não seja desperdiçado.

I. Domínio de Governança

EDM — Avaliar, Direcionar e Monitorar (Evaluate, Direct and Monitor)

Estes 5 objetivos são de responsabilidade da Alta Gestão/Diretoria.

EDM01: Framework de Gestão e Governança Assegurado.
EDM02: Benefícios Realizados (Valor para o negócio).
EDM03: Otimização de Riscos Assegurada.
EDM04: Otimização de Recursos Assegurada.
EDM05: Transparência para as Partes Interessadas Assegurada.

II. Domínios de Gestão

1. APO — Alinhar, Planejar e Organizar (Align, Plan and Organize)

Focado na estratégia, organização e planejamento da TI (14 objetivos).

APO01: Framework de Gestão de TI Gerenciado.
APO02: Estratégia Gerenciada.
APO03: Arquitetura Corporativa Gerenciada.
APO04: Inovação Gerenciada.
APO05: Portfólio Gerenciado.
APO06: Orçamento e Custos Gerenciados.
APO07: Recursos Humanos Gerenciados.
APO08: Relacionamentos Gerenciados.
APO09: Acordos de Serviço Gerenciados (SLAs).
APO10: Fornecedores Gerenciados.
APO11: Qualidade Gerenciada.
APO12: Risco Gerenciado.
APO13: Segurança Gerenciada.
APO14: Dados Gerenciados.

II. Domínios de Gestão (Continuação)

2. BAI — Construir, Adquirir e Implementar (Build, Acquire and Implement)

Focado na definição, aquisição e implementação de soluções (11 objetivos).

BAI01: Programas e Projetos Gerenciados.
BAI02: Definição de Requisitos Gerenciada.
BAI03: Identificação e Construção de Soluções Gerenciadas.
BAI04: Disponibilidade e Capacidade Gerenciadas.
BAI05: Mudança Organizacional Gerenciada.
BAI06: Mudanças de TI Gerenciadas.
BAI07: Aceite e Transição de Mudança de TI Gerenciados.
BAI08: Conhecimento Gerenciado.
BAI09: Ativos Gerenciados.
BAI10: Configuração Gerenciada.
BAI11: Projetos Gerenciados.

II. Domínios de Gestão (Continuação)

3. DSS — Entregar, Servir e Suportar (Deliver, Service and Support)

Focado na entrega operacional e suporte técnico (6 objetivos).

DSS01: Operações Gerenciadas.
DSS02: Requisições de Serviço e Incidentes Gerenciados.
DSS03: Problemas Gerenciados.
DSS04: Continuidade Gerenciada.
DSS05: Serviços de Segurança Gerenciados.
DSS06: Controles de Processos de Negócio Gerenciados.

II. Domínios de Gestão (Continuação)

4. MEA — Monitorar, Avaliar e Medir (Monitor, Evaluate and Assess)

Focado no monitoramento da conformidade e performance (4 objetivos).

MEA01: Monitoramento de Desempenho e Conformidade Gerenciados.
MEA02: Sistema de Controle Interno Gerenciado.
MEA03: Conformidade com Requisitos Externos Gerenciada.
MEA04: Garantia (Asseguração) Gerenciada.

EXEMPLO:
AMEAÇA DE ATAQUE DE RANSOMWARE

Exemplo

1. Identificação do Risco (Baseado no APO12.01*)

Ao coletar dados é identificado que sistemas legados não recebem atualizações há dois anos.

Ação: Registrar que há uma vulnerabilidade alta.

Pergunta do COBIT: "Qual o impacto financeiro e reputacional se os dados forem criptografados por atacantes?"

* APO12: Risco Gerenciado.

Exemplo

2. Análise e Avaliação (Baseado no APO12.02)

Descobre-se que a probabilidade é alta (devido aos sistemas antigos) e o impacto é crítico (interrupção de serviços da empresa).

Decisão de Governança (EDM03*): A diretoria avalia se aceita esse risco ou se investe para mitigá-lo. Eles decidem que o risco é inaceitável.

* EDM03: Otimização de Riscos Assegurada.

Exemplo

3. Resposta ao Risco (Baseado no APO12.03)

Para mitigar o risco, a empresa aciona outros objetivos do COBIT:

- BAI06 (Gerenciar Mudanças): Planejar a atualização imediata dos servidores;
- DSS05 (Serviços de Segurança): Implementar autenticação de dois fatores e novos firewalls;
- DSS04 (Gerenciamento de Continuidade): Garantir que os backups estejam offline e testados.

Exemplo

4. Monitoramento e Reporte (Baseado no APO12.06)

É criado um painel (Dashboard) para a diretoria mostrando quantos ataques foram bloqueados no mês e o status de atualização das máquinas.

Conexão com MEA01*: Monitorar se os controles de segurança estão realmente sendo executados pela equipe.

* MEA01: Monitoramento de Desempenho e Conformidade Gerenciados.

Universidade Presbiteriana Mackenzie

ITIL

Definição

A ITIL é uma biblioteca de melhores práticas para gerenciamento dos serviços de TI e melhoria do suporte de TI e dos níveis de serviço.

No ITIL a TI não entrega serviços, entrega valor.

4 Dimensões do ITIL

- Organizações e Pessoas: Cultura, competências e comunicação;

- Informação e Tecnologia: O conhecimento e as ferramentas necessárias;

- Parceiros e Fornecedores: Quem ajuda de fora (Cloud, consultorias, etc);

- Fluxos de Valor e Processos: Como as atividades se integram.

Exemplos de práticas do ITIL

Prática	O que faz	Exemplo
Central de Serviços (Service Desk)	Ponto único de contato	E-mail, telefone ou site
Gestão de Incidentes	Restaura o serviço o mais rápido possível	Queda do sinal de Internet
Gestão de Problemas	Investiga a causa raiz dos problemas	Por que o sinal da Internet caiu?
Gestão de Mudanças	Garante que as alterações não causem desastres	Atualizar o sistema na madrugada do sábado para o domingo
Gestão de Ativos	Controla o inventário	Onde está o laptop XYZ?

Universidade Presbiteriana Mackenzie

COBIT x ITIL

COBIT x ITIL

COBIT e ITIL não são concorrentes.

As empresas usam o COBIT para governar e o ITIL para operar.

O COBIT diz: "Precisamos garantir que os dados estejam seguros e os riscos controlados“, ou seja, o quê fazer.

O ITIL diz "Para garantir a segurança, vamos criar um processo de Gestão de Mudanças e um Service Desk para monitorar acessos.“, ou seja, o como fazer.

Universidade Presbiteriana
Mackenzie

Faculdade de
Computação e Informática